FIAP ON

GESTÃO DE RISCOS E VULNERABILIDADES

DISARTERS and RECOVERY

ABNER NETTO

07

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE FIGURAS

Figura 7.1 – Etapas do DRP.....10
Figura 7.2 – Serviços e Prioridades 13
Figura 7.3 – Implementação do DRP 15

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE QUADROS

Quadro 7.1 – Serviços x Impacto 12
Quadro 7.2 – Mitigação do Risco 14

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

SUMÁRIO

7. DISASTERS AND RECOVERY 5
7.1. Disaster Recovery Plan 6
7.2.1 Defina prioridades 10
7.2.2 Determine a abordagem técnica 13
7.2.3 Desenvolva e implemente 14
7.2.4 Teste o plano 16
REFERÊNCIAS 18

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

7. DISASTERS AND RECOVERY

O que aconteceria na sua companhia caso um incêndio acabasse destruindo seus servidores? Quanto tempo seria necessário para recuperar todos os dados e voltar a trabalhar? Existe algum procedimento padrão em casos de ocorrências como essa?

Se você não sabe a resposta para alguma das perguntas acima, esta é a hora de conhecer e aprender como lidar com um desastre em TI.

Com a automação de processos e a forte dependência dos meios de comunicação, como a Internet, é vital para as organizações a alta disponibilidade dos serviços de TI. As vulnerabilidades dos negócios são cada vez maiores. A virtualização, a infraestrutura definida pelo software e a computação em nuvem estão mudando a paisagem da TI (EITI, 2017). A paralisação dos serviços de TI afeta todas as operações da organização. As dificuldades começam desde o envio e recebimento de e-mails até o faturamento de produtos e serviços (FAGUNDES, 2021).

A informação é parte importante para os negócios de qualquer companhia no mundo. Com o rápido crescimento da quantidade de informação, como base de clientes, e-mails, propostas comerciais, dados dos usuários e vários outros sistemas, é necessário gerenciá-la de forma eficaz. Entretanto, várias emergências podem acontecer envolvendo os sistemas de informação, à medida que o ambiente se torna mais complexo e um ataque cibernético mais provável. Esses riscos podem resultar em danos à continuidade dos negócios e prejuízo às companhias (BACULA, 2021).

A possibilidade de ocorrer perda de dados e os consequentes prejuízos tangíveis (faturamento, clientes) e intangíveis (imagem, aceitação no mercado) em algumas companhias é da ordem de milhões de reais, podendo causar até a extinção total de uma organização em curto espaço de tempo, em caso de desastre (GUINDANI, 2008).

Alguns incidentes que podem afetar a continuidade do negócio são:

- Problemas com vulnerabilidades no sistema operacional e outras aplicações.
- Falhas no disco rígido (*hard disk*).

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Configurações incorretas em dispositivos de redes.
- Infecção da rede por um vírus.
- Falhas humanas.
- Incêndios.
- Inundações.
- Falha elétrica no *datacenter*.

Para tanto, a criação e manutenção de um plano de recuperação de desastre (*Disaster Recovery Plan*) é componente vital da estratégica de TI, com foco em proteger as funções críticas de negócios para manter sua continuidade. O plano define a ordem da solução de problemas quando um desastre acontecer.

7.1. Disaster Recovery Plan

O ***Disaster Recovery Plan*** **(DRP) ou Plano de Recuperação de Desastres** tem como objetivo permitir que uma organização sobreviva a um desastre e que possa restabelecer as suas operações de negócios.

Mas o que é um **desastre**?

Desastre é um evento cujo impacto é superior à capacidade de contenção. Se ocorre um evento e a TI consegue conter, não houve um desastre (MARINHO, 2018).

O DRP envolve uma análise minuciosa da estrutura de rede existente, aplicativos, bancos de dados, equipamentos, configuração da organização e detalhes relacionados. É importante definir no documento os principais componentes envolvidos no negócio, o pessoal da equipe de recuperação de desastres com detalhes de contato, objetivo de tempo de recuperação e métodos de comunicação no momento do desastre, instalação alternativa para a organização e lista principal de todos os inventários, locais de armazenamento, cliente/fornecedor, formulários e políticas (EITI, 2017).

Para Marinho (2018), o DRP é um documento formal de recuperação de ativos, que suportam as atividades (ou sistemas) críticos da organização. É um “passo a

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

passo” sobre como recuperar (ou substituir) um aplicativo, um equipamento, uma ferramenta ou mesmo uma pessoa, quando se torna indisponível, interrompendo a atividade (ou atividades) suportada.

Além disso, é necessário identificar quais eventos denotam possíveis desastres, quais pessoas na empresa têm autorização para declarar um desastre e, consequentemente, colocar o plano em ação. O documento deve oferecer, ainda, a sequência de eventos necessária para preparar o local de backup, uma vez declarado o desastre, o plano deve declarar as funções e responsabilidades de todo o pessoal envolvido na execução do plano, deve ainda definir o inventário do hardware e software necessários para restaurar a produção (ANDRADE et al., 2011).

Um plano de recuperação de desastres fornece informações e considerações sobre os processos necessários para restabelecer, testar e implementar os principais serviços de TI da companhia. O DRP geralmente contempla aspectos como:

- Instalações (energia, escritórios, equipamentos de escritórios etc.).
- Comunicação (internet, telefonia e e-mail).
- Hardware (servidores, estações de trabalho, impressoras etc.).
- Software (pacotes, desenvolvimentos internos e externos).
- Pessoal.

O DRP deve ser criado após o processo de Gestão de Riscos, pois a Análise de Impacto de Negócio (BIA) ajuda a revelar os sistemas críticos para operação da companhia e, respectivamente, o impacto no negócio.

Em qualquer organização que se prepara para a recuperação de desastres existem três pontos principais a serem considerados (EITI, 2017):

- **Prevenção:** medidas de segurança que possam prevenir os desastres antes que ocorram, como é o caso de backup e recuperação na nuvem, que evitam que os dados estejam vulneráveis a desastres naturais e outros acidentes que possam ocorrer na companhia.
- **Antecipação:** planejar e desenvolver medidas adequadas para combater desastres inevitáveis. Contratar um serviço de recuperação de desastres no

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

caso de um ataque de hackers para ter certeza de que todos os dados serão recuperados.

- **Mitigação:** gerenciar os desastres assim que ocorrem e, dessa forma, minimizar os seus impactos negativos. Um plano de recuperação de desastres deve garantir tempos adequados de retorno as atividades, com o menor prejuízos para as operações e os negócios.

A métrica para avaliar a eficácia de um DRP está baseada em dois conceitos:

- **RTO (*Recovery Time Objective*):** é o tempo necessário para as operações da companhia (serviços de TI) retornarem ao normal, após uma parada. O RTO é definido a partir de uma análise de impacto de negócios (*BIA – Business Impact Analysis*).
- **RPO (*Recovery Point Objective)*:** é a quantidade de dados que é tolerável perder em um incidente sem a possibilidade de recuperação por meio de um backup de dados.

Por exemplo, o DRP estima recuperar a infraestrutura de TI (RTO) em quatro horas depois de um desastre e o ponto de recuperação dos dados (RPO) é de uma hora. Para atingir o objetivo do RPO, é necessário manter cópia dos dados em um site backup (no mínimo a 10 km de distância) e sincronizar os dados depois da recuperação da infraestrutura (FAGUNDES, 2021).

Outro exemplo é a perda/falha do disco rígido do computador de um usuário do departamento Financeiro, usado para acessar bancos e enviar pagamentos. É possível o usuário usar outro computador do departamento ou da companhia? Esse novo computador tem todos os programas necessários para a realização do serviço? Existe backup das informações salvas localmente no computador? Quais são os principais programas do usuário? Existe a possibilidade de recuperação dos dados do disco danificado?

Nesse exemplo, a criticidade é indicada pela análise de tempo de tolerância (RPO) e pelo custo de parada (quais custos, tangíveis e intangíveis, uma vez ultrapassado esse prazo de tolerância).

Os gerentes de TI deveriam definir as ameaças potenciais e os riscos, estimando o tempo de parada (*downtime*) e o custo de recuperação de seus dados,

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

estações de trabalho e servidores de backup. A alta administração também deveria considerar seu envolvimento na criação do plano, a fim de escolher as melhores soluções para os riscos potenciais e garantir que os testes abranjam toda a organização, e atualizá-lo quando a infraestrutura mudar.

O DRP é um processo contínuo e iterativo. Cada etapa inclui várias atividades a serem realizadas (Figura “Etapas do DRP”). Durante o desenvolvimento inicial do DRP, as etapas 3 e 4 são repetidas várias vezes, focando no desenvolvimento e teste de planos de recuperação para um serviço diferente ou um conjunto de serviços.

A seguinte estratégia de recuperação pode ser desenvolvida no plano inicial de *Disaster Recovery*:

- Montar rapidamente uma equipe para trabalhar na recuperação.
- Informar os clientes (internos e externos) e parceiros sobre os problemas.
- Restaurar primeiro os serviços que tenham maior impacto na receita da companhia.
- Determinar o tempo de recuperação em dias úteis.

Como novos serviços são criados e serviços obsoletos são aposentados, prioridades e a abordagem técnica devem ser revisados periodicamente para garantir que eles sejam atuais.

Antes da elaboração de qualquer plano, é fundamental o apoio da alta direção/administração da organização, para que todos tenham ciência das políticas e regras que norteiam esses planos, e de uma rígida cultura organizacional voltada para seus colaboradores, a fim de que todos tenham consciência da importância de um plano de contingência (ANDRADE *et al*., 2011).

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

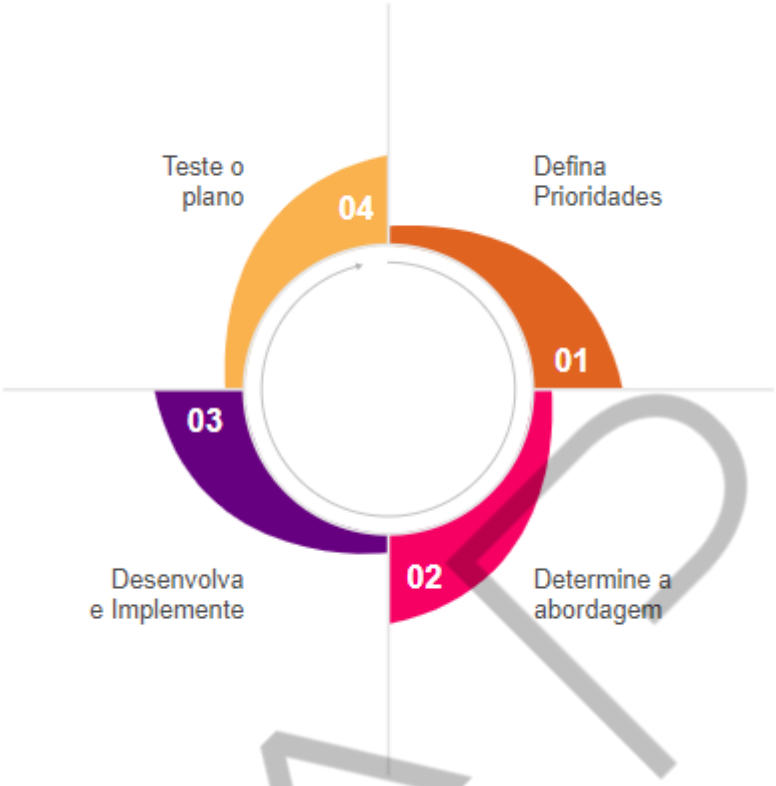

Figura 7.1 – Etapas do DRP
Fonte: Adaptado de Bacula (2020)

7.2.1 Defina prioridades

Para determinar os serviços cruciais para a continuidade do negócio, vamos definir as seguintes etapas:

- Identifique, em cada departamento da companhia, os serviços mais críticos para o negócio como um todo. Crie uma lista dos serviços críticos, provendo informações sobre os departamentos que são usados, localização, períodos críticos, soluções manuais (se disponíveis), tempo máximo de interrupção permitida, bem como os serviços ou aplicativos dependentes deles.
- Determine o impacto da interrupção do serviço e identifique os dados aceitáveis na perda e o tempo de inatividade do serviço. Uma interrupção do serviço de TI pode afetar uma organização de diversas maneiras. Existem cinco categorias que podem ser usadas para mesurar o impacto:
  - Segurança e a vida humana.
  - Financeiro.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Reputação.
- Operação.
- Leis e regulamentos.

Para cada serviço crítico e processo identificado, determine o seu impacto, usando os seguintes valores:

- **Baixo:** impacta somente um departamento, com baixa perda monetária.
- **Moderada:** impacta as operações comerciais, afetando pouco a prestação de serviços e processos. As consequências podem incluir perdas monetárias moderadas.
- **Alta:** As consequências ameaçariam a contínua prestação de serviços e processos, requerem envolvimento executivo. Podendo incluir danos ou destruição significativos, alguns pequenos ferimentos ou ameaça à segurança humana sem perda de vidas, com altas perdas monetárias.
- **Catastrófica:** impactam a operação dos serviços e processos essenciais, causando grandes problemas para os clientes. As consequências podem incluir grandes danos ou destruição, ameaça iminente à segurança humana, perda de vidas ou ferimentos graves, além de perdas monetárias extremas.

1. Avalie as ameaças e vulnerabilidades que podem causar interrupções nos serviços, processos e aplicativos de TI. Por exemplo, a sala de servidores sem um sistema de nobreak causando a parada em caso de queda de energia.
2. Priorize os serviços de TI de acordo com seus requisitos e sua criticidade:

- **Críticos** - dentro de 24 horas;
- **Vitais** – dentro de 72 horas;
- **Necessários** – dentro de duas semanas;
- **Desejados** – maiores que duas semanas, mas necessários para o retorno das operações ao normal.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

3. Decida quais serviços devem ser os primeiros a serem recuperados, com base na priorização, e quais podem aguardar.

SERVIÇO	AMEAÇA	IMPACTO				
		Segurança Física	Financeiro	Reputação	Operação	Aspectos Legais
Servidor de e-mail	Falha no disco	Baixa	Moderada	Baixa	Alta	Baixa
Servidor de arquivos	Vazamento de dados	Alta	Alta	Moderada	Baixa	Catastrófica
Servidor de arquivos	Infecção ransomware	Moderada	Catastrófica	Baixa	Catastrófica	Baixa
Datacenter	Incêndio	Catastrófica	Catastrófica	Baixa	Catastrófica	Baixa

Quadro 7.1 – Serviços x Impacto
Fonte: Elaborado pelo autor (2020)

No exemplo do Quadro “Serviços x Impacto”, foram descritos alguns serviços críticos para operação da companhia e mensurado o impacto para cada categoria. Veja que, pela sugestão de mensuração do impacto, as instalações do *Datacenter* deveriam ser prioridade no processo de recuperação por apresentar a maior quantidade de impacto catastrófico. Nesse caso, seria importante pensar em algumas medidas para mitigar o impacto: sistema de detecção de fumaça, gases inibidores (FM-200, CO_2), extintores de incêndio adequados para equipamentos elétricos, réplica física dos equipamentos a alguns quilômetros de distância do local original (site backup), replicar os dados na nuvem etc.

Algumas questões podem ser levantadas na definição dos serviços e prioridades:

- O impacto varia de acordo com a época do ano ou mês?
- Qual é o tempo máximo de interrupção permitido para cada serviço?
- Quão viáveis são as soluções alternativas?
- Em quanto tempo cada serviço de TI precisa estar disponível?
- Quantos dados ou informações podemos perder?

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Figura 7.2 – Serviços e Prioridades
Fonte: Adaptado de Bacula (2020)

7.2.2 Determine a abordagem técnica

Nesta etapa, você precisa determinar quanto investir na prevenção proativa de desastres, em vez de lidar com as consequências e se recuperar após um desastre. Depois de estabelecer prioridades de investimento, determine as facilidades e tecnologias necessárias, bem como o seu custo e qual deve ser o cronograma de implementação.

- Determinar a abordagem técnica para cada serviço:
  - Usando a lista de prioridades da etapa anterior, escolha se é melhor mitigar o risco ou focar nas opções de recuperação.
  - Para mitigar o risco pode se investir em equipamentos adicionais, de forma a criar contingência.
  - Focar na recuperação envolve soluções manuais e locais alternativos para restaurar os serviços e aplicações.
  - Leve em consideração o RTO e RPO de cada serviço. Serviços que possuem tempos curtos de recuperação devem optar pela prevenção e não pela recuperação.
- Desenvolver o plano de facilidades e infraestrutura:
  - Encontre um local alternativo com espaço físico suficiente, infraestrutura de rede e elétrica para recuperar os serviços de TI.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Esse local não pode ser muito próximo da localização original para garantir que o desastre não afete ambos. O recomendado é pelo menos 10 km de distância.

- Desenvolver as estimativas de custos e o cronograma:
  - Prepare estimativas de custos de mão de obra, tecnologias necessárias e o cronograma de implementação do plano de facilidades e infraestrutura (item 2).
  - Tenha aprovação do comitê diretor para evitar surpresas desnecessárias.

No quadro “Mitigação do Risco” podemos visualizar um exemplo de abordagem técnica para mitigar os riscos em um serviço crítico de TI.

SERVIÇO	RISCO	MITIGAÇÃO
Sistema de Gestão (ERP ou CRM)	Falha no fornecimento de energia elétrica (rompimento de alguma linha de distribuição).	Espelhe os servidores/aplicações em um datacenter. Restaure os dados do backup até que o fornecimento seja normalizado.
	Inundação, desastres naturais ou outro evento que impossibilite o uso das instalações atuais.	Espelhe os servidores/aplicações em um datacenter. Recupere os dados do backup. A instalação espelho se torna a instalação principal.
	Falha na rede de dados.	Adote uma abordagem preventiva por meio da configuração de componentes de rede redundantes, além de um provedor de Internet alternativo.
	Perda da aplicação.	Tenha a aplicação replicada em outro datacenter. Restaure os dados do backup.
	Perda de funcionários.	Crie uma documentação mais detalhada devido à criticidade do serviço. Se necessário, contrate temporariamente uma consultoria especializada durante um desastre.

Quadro 7.2 – Mitigação do Risco
Fonte: Adaptado de Bacula (2020)

7.2.3 Desenvolva e implemente

O desenvolvimento de um plano de recuperação de desastres (DRP) de TI requer o envolvimento de duas equipes:

- Um **comitê diretor** que toma decisões, autoriza tempo e recursos, fornece supervisão.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Um **grupo de trabalho** que define a abordagem técnica, desenvolve planos de recuperação para serviços individuais, além de testar e implementar esses planos.

A participação em cada equipe deve levar em consideração a autoridade de tomada de decisão, os recursos disponíveis para o profissional, suas habilidades e conhecimentos. Estabeleça funções e responsabilidades para os esforços de recuperação. Deve haver profissionais suplentes em cada equipe, pois nem todo mundo estará disponível no momento do desastre (colete os nomes e as informações de contato: celular, telefone fixo, telefone de recado, e-mail, função, departamento etc.).

É importante também que sejam formalizados os acordos contratuais com os fornecedores de hardware, software e serviços para suportar o plano de recuperação. As equipes de apoio ao plano de recuperação devem ser formadas e definidas suas responsabilidades no plano. Os padrões de recuperação devem ser consolidados nessa fase (FAGUNDES, 2021).

O processo de *Disaster Recovery* pode ser observado na Figura "Implementação do DRP": análise, recuperação, retorno do serviço e revisão do processo.

Figura 7.3 – Implementação do DRP
Fonte: Adaptado de Bacula (2020)

Depois que os serviços críticos forem identificados e os efeitos da falha analisados, desenvolva uma estratégia de recuperação para ajudar a prevenir ou reduzir as perdas financeiras. Um fator-chave para o desenvolvimento deve ser o entendimento de que o valor total da recuperação não pode exceder as perdas que ele foi projetado para evitar.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Quanto mais informações estiverem disponíveis do ambiente atual, como configuração de servidores, redes, segurança, aplicações, mais efetivo será o processo de recuperação de desastres. Documente todo o processo de recuperação do serviço, quando mais crítico o serviço, mais detalhada deve ser a documentação. Teste todo o processo de recuperação do serviço para identificar desvios e pontos de melhorias.

7.2.4 Teste o plano

O teste é a parte mais importante do desenvolvimento de um DRP, pois ele ajuda a determinar quais elementos não estão descritos e devem ser adicionados ao plano, bem como a eficácia do que foi planejado. Por exemplo, é comum utilizar um software de backup e automatizar suas tarefas diárias, mas tudo está funcionando? Somente um teste de restauração do backup, restaurando alguns arquivos ou pastas, pode confirmar isso. Ou seja, a única maneira de saber se o seu plano de recuperação de desastre funcionará em um desastre real é testá-lo completamente antes de ele ser realmente necessário.

Existem diferentes tipos de testes que variam em complexidade, quantidade de tempo e recursos para serem realizados, mas dois merecem atenção: teste de mesa e a simulação do desastre.

- **Teste de mesa:** os membros da equipe se reúnem e seguem verbalmente as etapas específicas, conforme documentado no plano, para confirmar a eficácia e identificar desvios, gargalos ou outros pontos fracos. Esse teste oferece a oportunidade de revisar o plano com toda a equipe e familiarizá-los com procedimentos, equipamentos e instalações externas.
- **Simulação de desastre:** uma simulação envolve o teste de hardware, software, pessoal, comunicações, procedimentos, suprimentos e formulários, documentação, transporte, utilidades e uso de local alternativo. Se possível, teste com dados de produção. Analise os resultados para capturar as lições aprendidas e atualize o plano conforme apropriado.

Uma das razões do fracasso de alguns planos é a falta de comprometimento das equipes na manutenção e testes do plano de forma contínua, o que resulta na

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

perda da compatibilidade do plano de recuperação com a realidade da empresa (FAGUNDES, 2021).

É importante que os testes sejam feitos periodicamente, todo mês, trimestralmente, semestralmente ou toda vez que qualquer elemento da infraestrutura for alterado. Toda vez que a recuperação é testada, são reveladas fraquezas e feitas melhorias no plano, isso gera mais confiança de que os negócios continuarão trabalhando, apesar dos problemas.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

REFERÊNCIAS

ANDRADE, D.; et. al. **Plano de Continuidade de TI:** preparando sua empresa para reagir a desastres e manter a continuidade do negócio. Pós-graduação em Segurança da Informação, FACSENAC, Brasília, 2011.

BACULA Systems. **IT Disaster Recovery Software Solution:** Sample Disaster Recovery Plan Template from Bacula Systems. 2021. Disponível em: <https://www.baculasystems.com/best-enterprise-data-backup-solutions/it-disaster-recovery-plan-template-software-solutions>. Acesso em: 26 fev. 2021.

EITI. **O que é um plano de recuperação de desastres?** 2017. Disponível em: <https://eitisolucoes.com.br/blog/o-que-e-plano-de-recuperacao-de-desastres/>. Acesso em: 26 fev. 2021.

FAGUNDES, E. **Disaster Recovery Plan (DRP)**. 2021. Disponível em: <https://efagundes.com/artigos/disaster-recovery-plan-drp>. Acesso em: 26 fev. 2021.

GUINDANI, A. Gestão da Continuidade dos Negócios**. Revista Integração UPIS**, [s.l.], V. 1, 2008. Disponível em: <https://upis.br/biblioteca/pdf/revistas/revista_integracao/gestao_continuidade.pdf>. Acesso em: 26 fev. 2021.

MARINHO, F. **Guia de Plano de Continuidade de Negócios (PCN).** [s.l.]: Atlas, 2018.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com